

Daily Vulnerability Report - 2026-09-27

Window (UTC): 2026-09-26T05:50 to 2026-09-27T05:50 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-27 05:50:56 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
216	216	0	0	0	16	105	83	5	171

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97163	New	10.0	CRIT				Joomla Extension - lomart.fr - Unauthenticated remote code installation in UP plugin extension 5.0.0-5.2.0, 6.0.0-6.0.29
CVE-2026-100716	New	9.9	CRIT				Froxlор is a server administration panel. In versions 2.3.10 and earlier, the customer data-export (DataDump) cron fails to validate intermediate path components of the export destination: Froxlор\FileDir::makeCorrectDir() contains an off-by-one in its path-component walk that skips the first segment below the customer home directory, and the guard in ExportCron.php checks o...
CVE-2026-100717	New	9.9	CRIT				froxlор is a server administration panel. In versions 2.3.10 and earlier, Validate::validateUrl rejects carriage return and line feed characters only in the path, query and fragment components returned by parse_url, and never inspects the userinfo (user:pass@) components. This is an incomplete fix for GHSA-c3p2. An authenticated low-privilege customer with subdomain-create r...
CVE-2026-100740	New	9.9	CRIT				A vulnerability was detected in D-Link DIR-895L A1_102b07. Impacted is the function tunnel_set_params of the file tunnel.c of the component L2TP Control Channel Parser. Performing a manipulation results in out-of-bounds write. The attack may be initiated remotely. The exploit is now public and may be used.
CVE-2026-18143	New	9.8	CRIT		0.004		The Request a Quote for WooCommerce plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 2.9.2 via the `afrfq_submit_quote_via_popup()` function. This is due to missing file extension and MIME type validation in the popup upload handler, which uses the raw attacker-supplied filename directly as the destination for `move_uploaded_f...
CVE-2026-82901	New	9.8	CRIT				The Ultra Addons for Contact Form 7 plugin for WordPress is vulnerable to Arbitrary File Upload due to insufficient file type validation in the 'uacf7_wpcf7_mail_components' function in all versions up to, and including, 3.5.50. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make remote code execution po...
CVE-2026-85984	New	9.8	CRIT				The miniOrange OTP Login, Verification and SMS Notifications plugin for WordPress is vulnerable to Authentication Bypass via the mo_wp_login_intent parameter in all versions up to, and including, 5.5.5. This is due to a missing password-intent guard in the skip_pass_fallback-enabled configuration branch of the mo_by_pass_login() function, which treats administrator role memb...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100715	New	9.6	CRIT				Froxlор through 2.3.10 is vulnerable to arbitrary file deletion via symlink following in the FTP data deletion cron task. Cron task 8 (deleteFtpData), queued when an FTP account is deleted, calls FileDir::makeCorrectDir() without the \$fixed_homedir argument, so the symlink component walk is skipped, and then executes 'rm -rf' as root on the resulting path with string-level g...
CVE-2026-94132	New	9.5	CRIT				Joomla Extension - acymailing.com - Remote Code Execution vulnerability in mailbox action feature in AcyMailing Enterprise extension < 11.1.0 - MIME parts of incoming emails were saved to media/com_acym/upload/ with no extension check, so anyone who could email the monitored mailbox could write a PHP file into the web root.
CVE-2026-100706	New	9.4	CRIT				kyverno before 1.19.1 fails to properly validate URL-encoded path segments in Policy apiCall urlPath, allowing namespace tenants to bypass the per-namespace clamp and create objects in other namespaces as the admission-controller ServiceAccount. Attackers can exploit this by using percent-encoded directory traversal sequences to create MutatingWebhookConfiguration objects cl...
CVE-2026-100714	New	9.4	CRIT				Froxlор before 2.3.12 does not restrict or escape the system.letsencryptchallengepath setting: unlike sibling settings hardened in GHSA-33mp, the field has no string_regexp or required_otp guard, and its value is concatenated unescaped into the acme.sh command line built in lib/Froxlор/Cron/Http/LetsEncrypt/AcmeSh.php and executed by the root cron via FileDir::safe_exec. Bec...
CVE-2026-97160	New	9.4	CRIT				Joomla Extension - lomart.fr - Authenticated, privileged PHP command injection in UP plugin extension 5.0.0-5.2.0, 6.0.0-6.0.29
CVE-2026-100720	New	9.3	CRIT				Froxlор 2.0.0 through 2.3.10 is vulnerable to stored cross-site scripting. When a customer (the lowest-privileged authenticated role) uploads an SSL certificate for one of their own domains, the Certificates API add()/update() methods parse it with openssl_x509_parse() and store the issuer organization (issuer['O']) value verbatim without sanitization. Froxlор's table-listin...
CVE-2026-94130	New	9.3	CRIT				Joomla Extension - joomlaboat.com - Unauthenticated SQL injection in YouTube Gallery extension < 5.7.3 - An SQL injection vulnerability in video search functionality and sorting allowed attackers to inject SQL commands in read queries.
CVE-2026-97161	New	9.2	CRIT				Joomla Extension - lomart.fr - Various path traversal / file access vectors in UP plugin extension 5.0.0-5.2.0, 6.0.0-6.0.29
CVE-2026-100721	New	9.0	CRIT				vm2 before 3.12.2 contains an authorization bypass in the NodeVM external-module resolver. When an embedder configures `require.external` with a custom resolver (and `context: 'host'`), `LegacyResolver.customResolve` in lib/resolver-compat.js records the resolved module directory in `this.externals` as `new RegExp('^' + escapeRegExp(resolvedPath))`, without requiring a path ...
CVE-2026-100614	New	8.8	HIGH				Capgo before 12.244.1 contains a cross-tenant integrity vulnerability in the metadata-cleaning worker that trusts image object keys from mutable database rows without validating ownership. An authenticated attacker can place a victim tenant's image key in a row they control, causing the service-role worker to download and re-upload that object with sanitized metadata. Attack...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100615	New	8.8	HIGH				Cap-go capgo.app before 12.267.1 fails to validate target API key privilege during rotation, allowing an apikey_manager to rotate a higher-privileged org_super_admin sibling key and recover its plaintext credential. Attackers with apikey_manager role can enumerate same-owner API keys, rotate a stronger sibling through the PUT endpoint, and obtain the replacement plaintext se...
CVE-2026-100617	New	8.8	HIGH				Cap-go capgo.app fails to validate that principals in channel_permission_overrides belong to the organization, allowing authenticated app/org admins to grant channel permissions to non-member users. Attackers with admin privileges can insert override rows with arbitrary external user UUIDs to grant channel-scoped permissions such as channel.promote_bundle to users outside th...
CVE-2026-100619	New	8.8	HIGH				Capgo (capgo.app) blocks direct user inserts into the public.manifest table with a RESTRICTIVE row-level security policy, but that restriction can be bypassed indirectly. A principal holding an app-scoped upload/write/all API key (upload+ rights) or an authenticated user with write+ rights on an app can update public.app_versions.manifest on a version whose storage_provider ...
CVE-2026-100623	New	8.8	HIGH				Capgo (capgo.app) exposes the legacy membership table public.org_users directly through Supabase PostgREST. The table's row-level security policies "Allow org admin to insert" and "Allow org admin to update" only verify that the caller has admin rights in the target organization (public.check_min_rights('admin', ...)); they do not require a pending invitation in tmp_users, a...
CVE-2026-100639	New	8.8	HIGH				SiYuan v3.8.3 fails to HTML-escape the data-subtype attribute when generating gutter-button markup (app/src/protyle/gutter/button.ts, assigned via innerHTML in app/src/protyle/gutter/index.ts) from content pasted as plain-text Markdown containing a Kramdown inline attribute list (IAL). Because the shared Lute renderer parses Kramdown IAL from text/plain input, an attacker-su...
CVE-2026-100670	New	8.8	HIGH				Grav CMS 2.0.14 through 2.0.24 contains a privilege escalation vulnerability in the group and account blueprints. The access map is gated by a `security@: admin.super` guard that is resolved by the field's exact path, so a submitted flat dot-notation key such as `access.admin.super` (instead of the nested `access[admin][super]`) matches no blueprint rule, survives BlueprintS...
CVE-2026-100679	New	8.8	HIGH				stoatchat before 0.15.5 fails to validate that MFA tickets belong to the authenticated user, allowing attackers to bypass MFA by using their own valid ticket with another user's session token. Attackers can obtain a ticket from their own account and use it with a victim's session token to disable TOTP, view recovery codes, or perform other sensitive operations without provid...
CVE-2026-100682	New	8.8	HIGH				Budibase Server before 3.45.0 contains an arbitrary file write vulnerability in the PWA icon upload endpoint that extracts user-supplied ZIP archives without proper symlink validation. Attackers with BUILDER role can craft a malicious ZIP with leaf symlink entries followed by duplicate file entries to write arbitrary files as root, enabling remote code execution.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100852	New	8.8	HIGH				AzuraCast through 0.23.x contains a command injection vulnerability in the Liquidsoap config generation for live recording that fails to quote the streamer username in process.run calls. Authenticated station users with Streamers and Profile permissions can set a username containing shell metacharacters and trigger command execution as the Liquidsoap process user when record...
CVE-2026-100856	New	8.8	HIGH				AzuraCast before 0.23.6 contains a code injection vulnerability in the remote relay password field due to incomplete migration from the vulnerable cleanUpString method to toRawString. Attackers with RemoteRelays station permission can inject nested Liquidsoap interpolation syntax to execute arbitrary code in the Liquidsoap process, disclose internal API keys, or disrupt stat...
CVE-2026-100864	New	8.8	HIGH				heym before 0.0.91 contains a sandbox escape vulnerability in the expression engine's DotList map/filter and fallback resolver that allows authenticated users to execute arbitrary Python code. Attackers can craft workflow expressions using dunder attribute access through item expressions or the fallback resolver to access os.system and execute commands as the backend process.
CVE-2026-100865	New	8.8	HIGH				Heym before 0.0.53 contains multiple independent vulnerabilities. (1) The workflow condition evaluator uses Python eval() without an effective sandbox, allowing any user who can edit a workflow branch/condition node — or who can import a workflow template containing a malicious condition node — to execute arbitrary Python code as the backend process user when the workflow ru...
CVE-2026-77203	New	8.8	HIGH				The Groups – Memberships and Access Control plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 4.6.0. This is due to the groups_join() function deriving group-join eligibility from the ambient post's author capabilities via the global \$post->post_author rather than from the currently authenticated user's own capabilities, while s...
CVE-2026-96524	New	8.8	HIGH		0.001		The MCP Server for WordPress WordPress plugin before 1.8.2 does not correctly verify the WordPress REST API nonce for cookie-authenticated requests when a condition an attacker can influence is present, allowing unauthenticated attackers to perform administrator-only actions, including creating a new administrator account, by tricking a logged-in administrator into visiting...
CVE-2026-100697	New	8.6	HIGH				Adminer 6.0.0 through 6.0.1, when the official ClickHouse driver plugin (plugins/drivers/clickhouse.php, rewritten in 6.0.0) is loaded, is vulnerable to pre-authentication server-side request forgery. An unauthenticated attacker can submit auth[driver]=clickhouse with auth[server] set to an arbitrary URL (for example http://127.0.0.1:18089), causing the Adminer server to iss...
CVE-2026-100618	New	8.5	HIGH				Capgo (capgo.app) is affected by an authorization flaw in the app icon update path. The PUT /app/:id endpoint accepts a user-controlled `icon` value, normalizes it, and stores it in public.apps.icon_url without verifying that the image path belongs to the target app's own image namespace (e.g. org/{owner_org}/{app_id}/...). Updating apps.icon_url fires the on_app_update trig...
CVE-2026-100693	New	8.4	HIGH				Hugo versions from v0.162.0 before v0.166.0 contain a case-sensitive validation flaw in the security.http.urls IP-literal deny rule that allows attackers to bypass restrictions. Attackers can use mixed-case URL schemes in resources.GetRemote calls to fetch from restricted IP addresses like localhost.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100839	New	8.4	HIGH				Contrast is a confidential-computing runtime for Kubernetes. In versions before 1.18.0, the guest kernel's ACPI/AML handling is vulnerable to an AML injection attack ("BadAML"). ACPI tables containing AML bytecode are passed from the untrusted host (QEMU) to the guest firmware (OVMF) and on to the Linux kernel, whose AML interpreter executes them. An attacker controlling the...
CVE-2026-100844	New	8.4	HIGH				MONAI before 1.6.0 is vulnerable to OS command injection in the nnUNetV2Runner component (monai.apps.nnunet.nnunetv2_runner). User-controlled values taken from the YAML configuration file (notably dataset_name_or_id) and from CLI/kwargs arguments are concatenated into a command string without quoting or validation and then passed to subprocess with shell=True, so shell metac...
CVE-2026-100608	New	8.3	HIGH				Flowise through 3.1.4 does not enforce authorization on the BullMQ admin dashboard. When the server runs in queue mode with the dashboard enabled and not in cloud mode (MODE=queue, ENABLE_BULLMQ_DASHBOARD=true, and lisCloud()), the /admin/queues mount is protected only by the verifyTokenForBullMQDashboard middleware, which validates the JWT but performs no role, permission, ...
CVE-2026-100705	New	8.3	HIGH				Kyverno before 1.19.1 is vulnerable to server-side request forgery. The default egress blocklist (169.254.169.254, 169.254.169.253, metadata.google.internal, 127.0.0.0/8, ::1/128) and the scoped-token control were wired only into the new CEL http.Get/Post library and were never applied to the legacy apiCall service executor (pkg/engine/apicall/executor.go) or to the GlobalCo...
CVE-2026-94131	New	8.3	HIGH				Joomla Extension - acymailing.com - Unauthenticated arbitrary file deletion in AcyMailing Enterprise extension < 11.1.0 - A subscriber could store a path in a file-type custom field and have AcyMailing delete that file when the field was cleared, including files outside the upload folder such as configuration.php.
CVE-2026-97162	New	8.3	HIGH				Joomla Extension - lomart.fr - Various SQL injection vectors in UP plugin extension 5.0.0-5.2.0, 6.0.0-6.0.29
CVE-2026-100673	New	8.2	HIGH				The Grav Data Manager plugin (getgrav/grav-plugin-datamanager) versions 1.0.1 through 1.4.4 render stored data entries in the item-detail view (admin/templates/partials/item.html.twig) without escaping, applying Twig's `raw` filter — in some cases after a striptags(' ') call that PHP's strip_tags() bypasses by preserving allowed tags together with their attributes. An una...
CVE-2026-100676	New	8.2	HIGH				January, the media proxy/embed service of stoatchat (stoatchat/stoatchat), before version 0.15.5 improperly resolves SVG <image href> values as local filesystem paths when a fetched resource is served as image/svg+xml. An unauthenticated remote attacker who causes the service to proxy an attacker-hosted SVG (e.g. via the /proxy endpoint) can determine whether local files exi...
CVE-2026-100702	New	8.2	HIGH				Nodemailer before 10.0.2 fails to properly flatten deeply nested arrays in recipient fields such as to, cc, and bcc, allowing attackers to cause stack exhaustion. Attackers can supply a deeply nested JSON recipient array that triggers recursive Array.toString() conversion, exhausting the call stack and terminating the Node.js process.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100833	New	8.2	HIGH				Contrast (edgelessssys/contrast) versions 1.14.0 before 1.23.1 generate runtime policies that fail to detect all container image substitutions. A bad rebase during a Kata Containers update accidentally introduced an `allow_storage` rule that accepts storage entries using the `image_guest_pull` driver without verifying the image digest. An attacker with access to the Kata agen...
CVE-2026-100627	New	8.1	HIGH				Capgo (Cap-go/capgo.app) server backend Supabase functions contain an incorrect authorization flaw in the API-key bundle promotion path. The PUT /bundle endpoint, available to "all" and "write" API keys, dispatches to setChannel, which authorizes with checkPermission(c, 'channel.promote_bundle', { appld: body.app_id }) and omits the request's channel_id. Because the omitted ...
CVE-2026-100646	New	8.1	HIGH				SiYuan is a self-hosted personal knowledge management system. In versions up to and including 3.8.3, the kernel's authentication guards (CheckAuth in kernel/model/session.go and IsSessionOriginAllowed in kernel/util/net.go) fail open when the HTTP Origin header is absent, on the incorrect assumption that any browser-initiated cross-site request carries an Origin. Because bro...
CVE-2026-100680	New	8.1	HIGH				Budibase versions before 3.45.0 fail to disable external JSON reference resolution in the OpenAPI/Swagger import validator, allowing authenticated builders to read arbitrary local files. Attackers with builder access can embed file:// references in OpenAPI specifications submitted to the import endpoint to exfiltrate sensitive files including environment variables containing...
CVE-2026-100684	New	8.1	HIGH				Budibase versions 3.41.0 before 3.45.0 contain an authentication bypass in the OIDC/SSO login path of @budibase/server. In sso.authenticate, when no existing user matches the incoming SSO subject, the server looks up pending user invites by the IdP-asserted email address alone — without validating an invite code and without an email_verified check (the email_verified gate pr...
CVE-2026-100686	New	8.1	HIGH				Budibase versions before 3.45.0 fail to validate per-app authorization in the POST /api/global/groups/:groupid/apps endpoint, allowing builders to assign application roles across workspace boundaries. A builder of a single workspace can exploit missing per-app authorization checks to grant themselves admin roles in other workspaces by modifying user group role mappings.
CVE-2026-100838	New	8.1	HIGH				Contrast is a confidential-computing runtime for Kubernetes. In versions before 1.19.1, the Kata agent policies generated by the Contrast CLI contained a flaw in the CopyFile verification that allowed arbitrary writes to the guest root filesystem. A malicious process on the untrusted host able to connect to the Kata agent VSOCK could issue a series of CopyFile requests to ov...
CVE-2026-100641	New	8.0	HIGH				SiYuan before v3.8.4 does not HTML-escape stored flashcard block content before interpolating it into the card-manager list markup. Block content returned by /api/riff/getRiffCards is inserted into a card item template in app/src/card/viewCards.ts and assigned to listElement.innerHTML, so content such as becomes an executable event-handler attri...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100643	New	8.0	HIGH				SiYuan versions before v3.8.4 fail to properly escape four stored Attribute View values in textarea elements, allowing authenticated attackers to inject JavaScript by modifying field descriptions, template sources, select option descriptions, or footer calculation templates. Attackers can execute stored JavaScript when other users open affected database menus, and in the Ele...
CVE-2026-100645	New	8.0	HIGH				SiYuan versions 3.7.0 before 3.8.4 contain a stored cross-site scripting vulnerability in gallery and kanban database renderers where field descriptions are not escaped in aria-label attributes. In the Electron desktop app with nodeIntegration enabled, attackers can inject JavaScript that calls Node.js child_process APIs to execute arbitrary commands with user privileges.
CVE-2026-100671	New	8.0	HIGH				Grav is a flat-file CMS. In versions 2.0.19 through 2.0.24 — and in 2.0.0 through 2.0.18 and 1.7.x only where content Twig has been explicitly enabled — page content authored by a user holding only page-write permission is rendered through a Twig sandbox that allowlists get_cookie(), which returns any cookie sent with the current request, including the visitor's session cook...
CVE-2026-100683	New	8.0	HIGH				Budibase (@budibase/server) before 3.45.0 builds MySQL and MSSQL column-rename DDL in packages/backend-core/src/sql/sqlTable.ts by interpolating identifiers directly into a raw query string (backtick-quoted for MySQL, a single-quoted sp_rename literal for MSSQL) without applying the project's quoteMySQLIdentifier / quoteSqlServerIdentifier helpers. An attacker with DDL right...
CVE-2026-100857	New	8.0	HIGH				AzuraCast before 0.23.4 contains a code injection vulnerability in the ConfigWriter::cleanUpString() method that fails to sanitize Liquidsoap string interpolation sequences, allowing authenticated users with Media or Profile permissions to inject arbitrary Liquidsoap code into station configuration. Attackers can inject #{process.run()} expressions into playlist URLs or stat...
CVE-2026-84095	New	8.0	HIGH		0.002		The wp-review-slider-pro WordPress plugin before 12.7.12 does not perform a capability check on one of its AJAX handlers, and the nonce protecting it is generated for every visitor, allowing any authenticated user, such as a subscriber, to store arbitrary review content which is later output without escaping on public pages, leading to Stored Cross-Site Scripting.
CVE-2026-84096	New	8.0	HIGH		0.002		The wp-review-slider-pro WordPress plugin before 12.7.12 does not perform a capability check on the AJAX handler that saves its review submission forms, and the nonce protecting it is generated for every visitor, allowing any authenticated user, such as a subscriber, to overwrite a live form with field values that are output without escaping on public pages, leading to Store...
CVE-2026-100840	New	7.8	HIGH				MONAI through 1.6.0 contains a remote code execution vulnerability in the bundle configuration engine that resolves _target_ values to arbitrary importable callables without an allow list and passes \$ expressions to Python eval(). Attackers can publish a malicious bundle with crafted configuration containing arbitrary code that executes when a victim loads the bundle using m...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100841	New	7.8	HIGH				In MONAI 1.6.0, PersistentDataset (monai/data/dataset.py) explicitly rejects the combination track_meta=True with weights_only=True, forcing users who cache MetaTensors (the default tensor type in MONAI >= 1.0) to run torch.load(hashfile, weights_only=False). Related cache helpers in monai/data/utls.py also call pickle.loads on cached content and derive cache keys with hash...
CVE-2026-100843	New	7.8	HIGH				MONAI versions before 1.6.0 contain a remote code execution vulnerability in the algo_from_pickle() function due to unsafe pickle.loads() deserialization in monai/auto3dseg/utls.py. Attackers can craft malicious pickle files that execute arbitrary system commands when deserialized by the vulnerable function.
CVE-2026-100845	New	7.8	HIGH				MONAI before 1.6.0 contains an unsafe deserialization vulnerability in the NumpyReader class that unconditionally uses numpy.load with allow_pickle=True when loading .npy and .npz files. Attackers can craft malicious .npy files with pickle payloads that execute arbitrary code when loaded through MONAI's standard data pipeline.
CVE-2026-100606	New	7.7	HIGH				Flowise through 3.1.4 (Enterprise/platform mode with SSO enabled) contains an authentication bypass in the SSO login path. When an SSO callback arrives with an email matching a user whose status is INVITED, verifyAndLogin (SSOBase.ts:80-94) copies the user record from the database — including the server-stored single-use invitation tempToken — into the data passed to Account...
CVE-2026-100607	New	7.7	HIGH				Flowise through 3.1.4 resolves SSO and local-password users solely by email without storing provider or subject identifier bindings, allowing attackers to authenticate as any existing user by claiming their email at any configured SSO provider. Attackers can gain complete account access including chatflows, credentials, and API keys by authenticating through a different SSO ...
CVE-2026-100685	New	7.7	HIGH				Budibase before 3.45.0 fails to properly scope the GET /api/chat-links endpoint by workspace, allowing builders to enumerate chat identity link records across all workspaces in a tenant. Attackers with builder access to a single workspace can retrieve sensitive chat identity linking data including user IDs and external chat service identifiers from other workspaces they have...
CVE-2026-100703	New	7.7	HIGH				Kyverno 1.16.0 through 1.19.0 registers the globalcontext.Lib CEL library in its policy environment without confining it to the policy's namespace, unlike the sibling libraries (resource.Lib, http.Lib, configMap loader) which are handed the policy namespace. A tenant who can create a namespaced policy (e.g. NamespacedValidatingPolicy, and likewise the namespaced mutating, de...
CVE-2026-100704	New	7.7	HIGH				Kyverno is a policy engine for Kubernetes. In versions 1.14.0 through 1.19.0, the ImageValidatingPolicy (policies.kyverno.io/v1beta1) evaluator never reads the spec.images and spec.allowedValues fields of a PolicyException. Any PolicyException whose policyRefs and matchConditions match a resource causes image signature verification to be skipped for the entire resource rather...
CVE-2026-100707	New	7.7	HIGH				Kyverno before 1.19.1 contains a namespace isolation bypass in the apiCall context entry of namespaced Policy resources due to inconsistent path interpretation between validation and execution. A low-privilege tenant can use percent-encoded dot-segments in urlPath to bypass namespace checks and read resources from other namespaces using the Kyverno admission controller's Ser...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100709	New	7.7	HIGH				Froxlor through 2.3.10 stores only a numeric user ID in remembered-2FA tokens (panel_2fa_tokens) without recording the account namespace, and the remembered-token lookup during login is not constrained to the customer or administrator account type. Because customer and administrator IDs are allocated from separate namespaces, a remembered-2FA token legitimately issued to a c...
CVE-2026-100850	New	7.7	HIGH				AzuraCast before 0.23.8 contains a server-side request forgery and local file read vulnerability in the AutoDJ remote playlist fetch (backend/src/Radio/AutoDJ/QueueBuilder.php, getMediaFromRemoteUrl()). A user with the station Media permission can create or update a playlist with source=remote_url and remote_type=playlist whose remote_url points at a file:// path or an inter...
CVE-2026-100636	New	7.6	HIGH				SiYuan versions before v3.8.4 contain a path traversal vulnerability in the exportBrowserHTML endpoint that allows authenticated administrators to write arbitrary HTML content to index.html outside the workspace directory. Attackers can supply a folder parameter with directory traversal sequences to escape the export directory and overwrite index.html in any pre-existing ker...
CVE-2026-100637	New	7.6	HIGH				SiYuan versions before v3.8.4 contain a path traversal vulnerability in the checkoutRepo endpoint that allows authenticated administrators to write JSON files outside the workspace. Attackers can supply a sessionID parameter containing directory traversal sequences to overwrite arbitrary JSON files in pre-existing kernel-writable directories outside workspace boundaries.
CVE-2026-100638	New	7.6	HIGH				SiYuan versions before v3.8.4 contain a path traversal vulnerability in the setNotebookIcon endpoint that allows authenticated administrators to create arbitrary directory trees and write files outside the workspace boundary. Attackers can supply directory traversal sequences in the notebook parameter to escape the workspace data directory and write conf.json files to arbitr...
CVE-2026-100642	New	7.6	HIGH				SiYuan versions from v2.1.0 before v3.8.4 contain a cross-site request forgery vulnerability in the CheckAuth lock-screen pass-through branch that grants administrator access to loopback requests without validating Origin headers. Attackers can craft malicious web pages that force victims to terminate the kernel process, read workspace configuration and proxy settings, and t...
CVE-2026-100846	New	7.6	HIGH				MONAI before 1.5.2 contains a deserialization of untrusted data vulnerability in the algo_from_pickle function in monai/auto3dseg/utlis.py. The function reads a .pkl file and passes its contents to pickle.loads without validating the data source or content. If an application invokes algo_from_pickle on an attacker-supplied pickle file, an object defining __reduce__ is execut...
CVE-2026-100851	New	7.6	HIGH				AzuraCast before 0.23.8 contains a broken access control vulnerability in the GET /api/station/{id}/vue/profile endpoint that allows authenticated users with only View Station Page permission to read Icecast/Shoutcast admin, source, and relay passwords. Attackers with View-only access can call this endpoint and receive plaintext frontend credentials in the JSON response, the...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100610	New	7.5	HIGH				Flowise through 3.1.4 exposes GET /api/v1/upsert-history/:id and PATCH /api/v1/upsert-history without route-level permission checks, and the backing service performs no workspace or ownership validation. getAllUpsertHistory() returns UpsertHistory rows selected solely by an attacker-supplied chatflowid, and patchDeleteUpsertHistory() deletes rows by an attacker-supplied arra...
CVE-2026-100622	New	7.5	HIGH				capgo.app through 12.129.0 fails to verify deletion status when serving cached bundle artifacts from the public file read endpoint. Unauthenticated attackers can download deleted bundles using cached URLs and trigger restoration of deleted objects into R2 storage on cache hits.
CVE-2026-100631	New	7.5	HIGH				Parse Server is an open source backend server. In versions prior to 8.6.90 and in versions from 9.0.0 prior to 9.10.1-alpha.9, the device token deduplication logic for installation records does not validate the type of client-supplied installation fields before using them to build database queries. An unauthenticated remote attacker who knows only the public application ID c...
CVE-2026-100644	New	7.5	HIGH				SiYuan before v3.8.4 contains a SQL injection vulnerability in the graph query endpoint where the dailyNoteSavePath parameter is concatenated into SQL without escaping. Unauthenticated attackers on published sites with auth disabled can inject SQL via UNION SELECT to extract arbitrary database rows from all notebooks.
CVE-2026-100655	New	7.5	HIGH				Netty (io.netty:netty-codec-http) versions up to and including 4.1.137.Final and from 4.2.0.Final through 4.2.17.Final accept an unlimited number of concurrent remote-initiated SPDY streams: SpdySessionHandler defaults localConcurrentStreams to Integer.MAX_VALUE and exposes no API to change it. A remote peer that opens a SPDY connection and sends millions of SYN_STREAM frame...
CVE-2026-100656	New	7.5	HIGH				Netty (io.netty:netty-codec-http) contains an unbounded per-connection queue growth flaw in HttpServerCodec. The codec tracks the HTTP method of each still-unanswered pipelined request; the first 32 entries are bit-packed into a single long, but every additional entry is appended to methodOverflowQueue, an ArrayDeque with no size limit and no rejection path. A remote, unauth...
CVE-2026-100657	New	7.5	HIGH				Netty's STOMP codec (io.netty:netty-codec-stomp) contains a ByteBuf leak in StompSubframeDecoder. Once a frame's declared content-length has been fully read, the decoder allocates a chunk buffer from the channel allocator and parks it in an instance field while waiting for the single NUL byte that terminates the frame. If that byte never arrives, the buffer is never released...
CVE-2026-100660	New	7.5	HIGH				Netty's HTTP/3 codec (io.netty:netty-codec-http3) from 4.2.0.Final through 4.2.17.Final retains unbounded per-stream QPACK encoder state. QpackEncoder stores a queue and a dynamic-table index tracker for every encoded field section that references the QPACK dynamic table, keyed by the peer-controlled QUIC stream ID, and these entries are released only when the remote decoder...
CVE-2026-100661	New	7.5	HIGH				Netty's HTTP/3 codec (io.netty:netty-codec-http3) versions 4.2.0.Final through 4.2.17.Final contain a denial-of-service vulnerability in the QPACK prefixed-integer decoder (QpackUtil.decodePrefixedInteger), which does not bound the number of continuation bytes it will process. A remote, unauthenticated peer can open a QPACK unidirectional stream (type 0x02 encoder or 0x03 de...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100662	New	7.5	HIGH				Netty's HTTP/3 codec (io.netty:netty-codec-http3) versions 4.2.0.Final through 4.2.17.Final contain an uncontrolled resource consumption vulnerability in the QPACK encoder-stream instruction decoder (QpackEncoderHandler, installed on the peer-initiated unidirectional QPACK encoder stream, type 0x02). The handler accepts an attacker-declared string-literal length of up to Int...
CVE-2026-100663	New	7.5	HIGH				Netty's HTTP/3 codec (io.netty:netty-codec-http3) from 4.2.2.Final through 4.2.17.Final does not special-case HTTP/1 CONNECT authority-form request-targets when converting HTTP/1 messages to HTTP/3 in HttpConversionUtil.toHttp3Headers. The authority-form target (e.g., "CONNECT trusted.example:443") is parsed as a URI, so its host is emitted as :scheme, :path is set to "/", a...
CVE-2026-100664	New	7.5	HIGH				Netty's HTTP/3 codec (io.netty:netty-codec-http3) versions 4.2.2.Final through 4.2.17.Final builds the HTTP/3 :authority pseudo-header from the HTTP/1 Host header before considering the authority of an absolute-form HTTP/1 request-target. In HttpConversionUtil.toHttp3Headers(HttpMessage, boolean) — reached via Http3FrameToHttpObjectCodec(false) — a non-empty Host header take...
CVE-2026-100665	New	7.5	HIGH				Netty versions from 4.2.11.Final before 4.2.18.Final contain an incomplete hostname verification fix in the QUIC certificate verification path when using a plain X509TrustManager. The BoringSSLCertificateVerifyCallback discards the SSLEngine for plain trust managers, preventing endpoint identification from running even when HTTPS verification is configured. Attackers on the ...
CVE-2026-100669	New	7.5	HIGH				Grav before 2.0.25 ships web server configuration samples whose access-control deny rules are matched case-sensitively. In webserver-configs/web.config (IIS), every deny rule (user_sensitive_folders, user_accounts, user_data, user_error_redirect, user_pages, system, vendor, ignore_folders) sets ignoreCase="false" on its URL Rewrite <match> element, overriding the IIS default...
CVE-2026-100672	New	7.5	HIGH				The Comments plugin (getgrav/grav-plugin-comments) for Grav CMS through version 1.2.10 registers an admin handler that returns comment data as JSON without any authentication check. The handler branches on isAdmin(), which only indicates that the admin service is registered on the current route rather than that the visitor is authenticated, and it echoes the JSON and calls e...
CVE-2026-100690	New	7.5	HIGH				Hugo versions from v0.161.0 through v0.165.0 run Node.js tools (css.PostCSS, css.TailwindCSS, js.Babel) under the Node.js permission model to restrict file system reads to the project directory and configured mounts. Because the Node.js permission model validates only the lexical path and follows symbolic links that point outside the allowed set, Hugo did not detect symlinks...
CVE-2026-100692	New	7.5	HIGH				Hugo is a static site generator. In versions after v0.123.0 and before v0.166.0, Hugo's symlink confinement checks stopped at the mount root itself, so a theme or module checked into themes/ (or a vendored module) could contain a symlink at a mount root (for example themes/mytheme/assets -> /some/dir/outside). Files behind such a symlink were readable during a site build thr...
CVE-2026-100700	New	7.5	HIGH				nodemailer before 10.0.6 contains a denial of service vulnerability in the addressparser free-text fallback regex pattern that exhibits quadratic backtracking behavior. Attackers can supply crafted email header values with long whitespace-free runs to block the Node.js event loop for tens of seconds, causing service unavailability.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100711	New	7.5	HIGH				froxlор versions before 2.3.12 fail to invalidate existing panel sessions, API keys, and 2FA trust cookies when a user password is changed. Attackers holding hijacked sessions, valid API keys, or 2FA trust tokens retain full account access after password rotation, bypassing incident response actions.
CVE-2026-100723	New	7.5	HIGH				vm2 before 3.12.2 does not apply its Buffer backing-store ownership invariant (byteOffset === 0 and buffer.byteLength === length) to Buffers returned from host builtin modules. When an application explicitly exposes Node's zlib module through NodeVM's builtin allowlist (require: { builtin: ['zlib'] }), zlib.deflateSync can return a Buffer backed by Node's shared small-buffer...
CVE-2026-100847	New	7.5	HIGH				AzuraCast before 0.23.8 contains a DQL injection vulnerability in the sortOrder API parameter of AbstractSearchableListAction.php. Attackers can inject arbitrary DQL expressions through the sortOrder parameter to extract sensitive database information including user credentials and station settings.
CVE-2026-85081	New	7.5	HIGH		0.002		The File Manager WordPress plugin before 8.0.5, FileOrganizer WordPress plugin before 1.2.1, File Manager Pro WordPress plugin before 2.1.3 do not correctly validate the origin of window messages received by the file browser they load on their admin screens, accepting any origin that is a leading string prefix of the site's own address, which allows an unauthenticated atta...
CVE-2026-96532	New	7.5	HIGH		0.001		The Testimonials Widget WordPress plugin through 4.0.4 does not perform a capability or ownership check when handling its front-end testimonial submission form, allowing unauthenticated users to modify or create arbitrary posts, including overwriting the title, content and author of any existing post.
CVE-2026-100835	New	7.4	HIGH				Contrast before 1.16.0 is susceptible to remote attestation relay attacks. Contrast accepted any TEE attestation report that verified correctly and contained the expected firmware patch levels and software measurements, regardless of which machine produced it, so attestation was not bound to specific, physically trusted hardware. An attacker who can both intercept network tr...
CVE-2025-71423	New	7.3	HIGH				EdgelessSys Contrast is a confidential-computing runtime for Kubernetes. In versions 1.9.0 before 1.12.2, the initializer logs the full NewMeshCert response — which contains the workload secret — to standard output at INFO level. As a result, workload secrets are exposed to any Kubernetes user with get or list permission on pods/logs. Because workload secrets are used for en...
CVE-2025-71425	New	7.3	HIGH				Contrast (Edgeless Systems) before 1.8.1 logs the workload secret to stderr, and thus to Kubernetes logs, when the Contrast initializer is configured with CONTRAST_LOG_LEVEL set to info or debug. Because info is the default, all installations that do not customize the initializer log level are affected. This exposes workload secrets — normally accessible only to the Contrast...
CVE-2026-100314	New	7.3	HIGH				A security vulnerability has been detected in mathurvishal CloudClassroom-PHP-Project up to 5dade098bfbf3300d60c3494db3fb95b66e7be. This impacts an unknown function of the file updatedetailsfromstudent.php. The manipulation of the argument eno leads to sql injection. The attack can be initiated remotely. The exploit has been disclosed publicly and may be used. Continuous d...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100315	New	7.3	HIGH				A vulnerability was detected in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. Affected is an unknown function of the file mydetailsfaculty.php. The manipulation of the argument myfid results in sql injection. The attack can be launched remotely. The exploit is now public and may be used. This product does not use versioning. This is ...
CVE-2026-100666	New	7.3	HIGH				Netty's HttpServerCodec (io.netty:netty-codec-http) in versions 4.2.0.Final through 4.2.16.Final and in versions up to and including 4.1.136.Final pairs each outbound response with an inbound request by calling pollMethod() once per response, including for 1xx informational responses. If a client pipelines an HTTP/1.1 GET carrying an Expect: 100-continue header followed by a...
CVE-2026-100739	New	7.3	HIGH				A vulnerability was detected in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. This impacts an unknown function of the file viewresult.php. Performing a manipulation of the argument seno results in sql injection. Remote exploitation of the attack is possible. The exploit is now public and may be used. This product follows a rolling re...
CVE-2026-100744	New	7.3	HIGH				A flaw has been found in coolabsio Coolify up to 4.1.2. The affected element is an unknown function of the file app/Http/Middleware/CanUpdateResource.php of the component Route-Level Middleware. Executing a manipulation can lead to missing authorization. The attack may be launched remotely. The exploit has been published and may be used. Upgrading to version 4.2.0 is suffic...
CVE-2026-100746	New	7.3	HIGH				A vulnerability was found in coolabsio Coolify up to 4.1.0. This affects the function Github::redirect of the file /webhooks/source/github/redirect of the component GitHub App Setup Handler. The manipulation of the argument state results in missing authentication. The attack can be executed remotely. The exploit has been made public and could be used. Upgrading to version 4...
CVE-2026-72668	New	7.3	HIGH				Unintended Proxy or Intermediary ('Confused Deputy') (CWE-441) in Kibana Agent Builder can lead to privilege escalation. A non-administrative user able to edit a shared agent could cause privileged operations to be carried out under the identity of a higher-privileged user who subsequently interacts with that agent. Where the same user can also author workflows, this can ext...
CVE-2026-100612	New	7.2	HIGH				Capgo (capgo.app) through version 12.261.0 contains an incomplete access-control fix for the public.sso_providers table. Migration 20260826100000_sso_providers_block_direct_active_insert.sql installs a BEFORE UPDATE guard (enforce_sso_provider_client_update_guard()) that freezes only the dns_verified_at, domain, status and enforce_sso columns; provider_id (as well as metadat...
CVE-2026-16591	New	7.2	HIGH		0.002		The WP Directory Kit WordPress plugin before 1.5.8 does not sanitize and escape some of its category and location fields before outputting them in page attributes, allowing users with a WP Directory Kit WordPress plugin before 1.5.8-specific listing-management role (and without the unfiltered_html capability) to perform Stored Cross-Site Scripting attacks that execute for an...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2025-71426	New	7.1	HIGH				Contrast is a confidential-computing runtime for Kubernetes. In versions before 1.4.1, a recovering Coordinator does not verify the seed supplied by the recovering party. An attacker can therefore stand up a rogue Coordinator whose manifest passes validation but whose secret seed is attacker-controlled. If network traffic is redirected from the legitimate Coordinator to the ...
CVE-2026-100605	New	7.1	HIGH				Flowise through 3.1.4 contains missing route-level RBAC checks on chat message endpoints that allow low-privileged API keys to read and delete chat history. Attackers with valid but low-privileged API keys can access GET and DELETE chat message routes without required flow permissions to read chat histories, prompts, model responses, and delete messages.
CVE-2026-100625	New	7.1	HIGH				Capgo (capgo.app) exposes a native build TUS upload proxy (supabase/functions/_backend/public/build/upload.ts) that authorizes a caller against a single build job identified by the supplied builder_job_id and validates only that job's stored upload_path, but then forwards the user-controlled TUS resource suffix taken from /build/upload/:jobId/* to the builder service while i...
CVE-2026-100708	New	7.1	HIGH				Froxlor before 2.3.13 returns the ssl_key_file column — which stores the raw PEM TLS private-key content — verbatim in the JSON responses of the Certificates.get and Certificates.listing API commands, because the results of the underlying domain_ssl_settings queries are passed through ApiCommand::response() without any field stripping or allowlist. A low-privileged authentic...
CVE-2026-100713	New	7.1	HIGH				Froxlor 2.3.10 and earlier contain a time-of-check time-of-use (TOCTOU) race condition in the SSH key synchronization cron (lib/Froxlor/Cron/System/SshKeys.php, SshKeys::generateFiles). The containment/symlink validation performed by FileDir::makeCorrectDir()/makeCorrectFile() is done only at check time; the live filesystem path is re-resolved as root at write time (file_put...
CVE-2026-100718	New	7.1	HIGH				Froxlor through 2.3.10 does not enforce the mail.allow_external_domains policy in the EmailSender.add API command. When an administrator has enabled the allowed-sender feature but disabled external allowed-sender domains (mail.enable_allow_sender = 1, mail.allow_external_domains = 0), an authenticated customer with API access can still use EmailSender.add to register an arbi...
CVE-2026-100719	New	7.1	HIGH				Froxlor versions before 2.3.12 contain a credential disclosure vulnerability in the DirProtections.listing API command that returns httpasswd password hashes. Authenticated API users can retrieve bcrypt password hashes for protected-directory users, enabling offline cracking attempts and exposure of reused credentials.
CVE-2026-100848	New	7.1	HIGH				AzuraCast (Composer package azuracast/azuracast) before 0.23.8 validates a station's "Remote Relay" URL only for URL syntax and an http/https scheme (Utilities\Urls::parseUserUrl, used by StationRemote::getUriAsUri) and performs no host or IP address restriction. A user holding only the station-scoped RemoteRelays permission can therefore set a Remote Relay URL pointing at l...
CVE-2026-100849	New	7.1	HIGH				AzuraCast is a self-hosted web radio management suite. In AzuraCast before 0.23.8, the station webhook URL validation in AbstractConnector::getValidUrl() (backend/src/Webhook/Connector/AbstractConnector.php), used by the Generic and Discord webhook connectors, rejects only URLs whose host is a literal link-local IP address (169.254.0.0/16 or fe80::/10). Loopback addresses an...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100842	New	7.0	HIGH				MONAI through 1.6.0 contains an eval injection vulnerability in <code>_get_fake_spatial_shape()</code> in <code>monai/bundle/scripts.py</code> . The function validates shape expressions with a helper that walks the AST and only collects <code>ast.Name</code> nodes, rejecting any name other than 'p' or 'n', before passing the string to <code>eval()</code> . Expressions built solely from constants and attribute, subscript, or cal...
CVE-2026-100710	New	6.9	MEDI				Froxlор through 2.3.10 does not filter sensitive columns from API responses: <code>Domains::get()</code> , <code>Domains::listing()</code> , <code>SubDomains::get()</code> , and the admin branch of <code>SubDomains::listing()</code> perform a wildcard SELECT over the <code>panel_domains</code> table and return the row unmodified, including the <code>panel_domains.dkim_privkey</code> field. An authenticated, non-superadmin admin holding the delegated cust...
CVE-2026-100609	New	6.8	MEDI				Flowise (npm packages <code>`flowise`</code> and <code>`flowise-components`</code>) through 3.1.4 looks up credentials by ID without filtering on the requesting user's workspace (<code>findOneBy({ id: credentialId })</code> with no <code>workspaceId</code> condition) in several code paths: <code>getAllOpenaiAssistants/getSingleOpenaiAssistant</code> (GET <code>/api/v1/openai-assistants</code> and <code>/api/v1/openai-assistants/:id</code>), <code>uploadFilesToAssistant</code> ...
CVE-2026-100722	New	6.8	MEDI				vm2 before 3.12.2 does not apply host-side Promise rejection handling in the sandbox-to-host construct trap. In <code>BaseHandler</code> , the <code>apply</code> trap calls <code>markHostPromiseHandled()</code> on the returned value, but the adjacent construct path returns the result of <code>Reflect.construct</code> without the same sanitization. If an embedder exposes a constructable host function whose constructor returns a...
CVE-2026-100858	New	6.8	MEDI				heym before 0.0.109 contains a server-side request forgery vulnerability in the Slack, Discord, and Crawler workflow nodes. These nodes issue HTTP requests to URLs taken from user-created credentials (<code>webhook_url</code> / <code>flaresolvert_url</code>) using an unguarded HTTP client, bypassing the SSRF egress guard that already protects the HTTP, WebSocket, and MCP nodes; the credential API val...
CVE-2026-89237	New	6.8	MEDI		0.002		The Bluff Post WordPress plugin through 1.1.1 does not sanitise and escape parameters before using them as identifiers in a SQL query, allowing unauthenticated attackers to append additional SQL and extract sensitive information from the database.
CVE-2026-92411	New	6.8	MEDI		0.002		The WP Delicious WordPress plugin before 1.10.8 does not validate or escape the HTML tag name taken from user-supplied recipe block data before rendering it on the front end, allowing users with the Contributor role and above to inject arbitrary HTML tags, including script tags, which execute when the recipe page is viewed.
CVE-2026-96531	New	6.8	MEDI		0.002		The Optimole WordPress plugin before 4.2.13 does not escape unrecognized attributes of its video-player block before rendering them onto the block's wrapper element, allowing users with the Author role and above to store an event-handler attribute that executes scripts in the browser of any user, such as an administrator, who views the post.
CVE-2026-100602	New	6.5	MEDI				ClawHub (openclaw/clawhub application/backend) contains a missing authorization check in the changelog preview feature. A signed-in caller can invoke the public <code>skills:generateChangelogPreview</code> action for a skill they are not authorized to access; the previous version is read without the file-read authorization enforced on normal content access, and up to 8,000 characters of ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100611	New	6.5	MEDI				Capgo (capgo.app backend, versions $\leq$ 12.261.0) improperly restricts which roles the apikey_manager organization role may bind to newly created API keys. When an authenticated user holding only apikey_manager (permissions org.manage_apikeys and org.read) calls POST /apikey with a JWT session, the only checks applied are the org.manage_apikeys permission, a fixed deny-list of ...
CVE-2026-100632	New	6.5	MEDI				Parse Server is an open-source backend server. In versions $\geq$ 9.0.0 and $<$ 9.10.1-alpha.8, and in versions $<$ 8.6.89, LiveQuery evaluates the protectedFields class-level permission against an incompletely resolved caller identity: the subscriber's roles are not resolved, and when a subscription does not supply its own session token the event payload is redacted against an anon...
CVE-2026-100633	New	6.5	MEDI				SiYuan is a self-hosted personal knowledge management system. In versions 3.8.0 through 3.8.3, the MCP file tool's sensitive-path guard (util.IsForbiddenAbsPath(), invoked from resolvePath()) is applied only to the allowed root of recursive operations and not to each resolved descendant path — an incomplete fix for GHSA-c8r8-95hg-mp34. An authenticated administrator using th...
CVE-2026-100650	New	6.5	MEDI				vLLM through 0.29.0 fetches and fully materializes remote or inline media before enforcing its documented media controls (the VLLM_MAX_AUDIO_CLIP_FILESIZE_MB compressed-audio size cap, default 25 MB, and the per-modality --limit-mm-per-prompt item limits). Across four ingress paths — the shared media-acquisition layer (HTTPConnection.get_bytes()/async_get_bytes()), the chat ...
CVE-2026-100651	New	6.5	MEDI				vLLM before 0.29.0 fails to enforce decoder prompt-length validation on the disaggregated serving endpoint /inference/v1/generate. When the request contains a 'features' (multimodal) payload, vllm/entrypoints/serve/disagg/serving.py builds a Multimodal EngineInput directly from the caller-supplied token_ids, and GenerateRequest.token_ids (vllm/entrypoints/serve/disagg/protoc...
CVE-2026-100653	New	6.5	MEDI				vLLM is an inference and serving engine for large language models. In versions from 0.22.1 through 0.28.0, the operator-supplied model revision pin (--revision / --code-revision) is not propagated to several Hugging Face artifact loads for the FunAudioChat and Tarsier2 architectures: the WhisperFeatureExtractor and speech_tokenizer PreTrainedTokenizerFast loads in vllm/model...
CVE-2026-100654	New	6.5	MEDI				vLLM before 0.29.0 accepts user-controlled stop_token_ids on the OpenAI-compatible POST /v1/completions and POST /v1/chat/completions endpoints but validates only that the values are integers, not that each token id is within the model vocabulary/logits range. When min_tokens $>$ 0, the stop token ids are used as logits indices to suppress stop tokens, so an out-of-range id re...
CVE-2026-100659	New	6.5	MEDI				Netty's HTTP/3 codec (io.netty:netty-codec-http3) in versions 4.2.0.Final through 4.2.17.Final does not enforce the RFC 9114 requirement that the :authority pseudo-header field and a literal host header field, when both present, carry the same value. A remote unauthenticated peer can send a single HEADERS frame containing both fields with differing, attacker-controlled value...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100668	New	6.5	MEDI				Grav 2.0.0 through 2.0.24 contain a Twig content sandbox escape. The `array` filter (and its identical function form) is on the sandbox allowlist but is registered without the needs_is_sandboxed guard that print_r, vardump, json_encode, yaml_encode and string carry, and its implementation calls toArray() — or falls back to an (array) cast — without consulting the sandbox met...
CVE-2026-100675	New	6.5	MEDI				stoatchat versions before 0.15.5 contain a denial of service vulnerability in the acknowledgement worker that processes mass mention messages. Authenticated users can send five crafted role-mention messages to terminate all acknowledgement workers, disabling push notifications and mention badges deployment-wide until the API process restarts.
CVE-2026-100678	New	6.5	MEDI				stoatchat before 0.15.5 fails to enforce account-level attempt limits on MFA login challenges, allowing attackers who know a password to guess TOTP codes with only IP-based rate limiting. Attackers can reuse MFA challenge tickets across multiple failed attempts and distribute guesses across IP addresses to bypass rate limiting and gain account access.
CVE-2026-100688	New	6.5	MEDI				Budibase server before 3.45.0 contains a cross-tenant information disclosure vulnerability in the GET /api/applications/:appId/appPackage endpoint that allows authenticated users to read another tenant's application metadata and source code. Attackers can supply a victim tenant's app id to retrieve sensitive application details including navigation structure, role names, int...
CVE-2026-100712	New	6.5	MEDI				froxl through 2.3.10 disables a user's two-factor authentication immediately upon an unauthenticated-triggerable GET request to the 2FA management page (e.g. /customer_index.php?page=2fa&action=delete), with no confirmation, re-authentication, or CSRF token. The global CSRF middleware only covers POST/PUT/PATCH/DELETE requests, and the session cookie is set to SameSite=Lax...
CVE-2026-100725	New	6.5	MEDI				http4k (Maven artifact org.http4k:http4k-core) before 6.48.0.0, 5.42.0.0, and 4.51.0.0 ships a BasicCookieStorage (client-side cookie store used by ClientFilters.Cookies) that does not enforce RFC 6265 scoping rules for the cookie domain, path, and Secure attributes. When a single BasicCookieStorage instance is used to talk to more than one origin or scheme, cookies stored f...
CVE-2026-100855	New	6.5	MEDI				AzuraCast before 0.23.6 contains a missing permission check vulnerability in the GET /api/station/{station_id}/file/{id}/play endpoint that allows authenticated users to download media files from any station. Attackers can enumerate media files using sequential IDs and exfiltrate the complete media library of stations they lack permissions for.
CVE-2026-100859	New	6.5	MEDI				Heym before 0.0.106 contains a credential exfiltration vulnerability in the POST /api/credentials/test endpoint that allows collaborators with shared credential access to exfiltrate the credential owner's secret. Attackers can override the destination URL in the config parameter to cause the server to send decrypted authentication secrets to attacker-controlled endpoints.
CVE-2026-78582	New	6.5	MEDI				Missing Authorization (CWE-862) in Kibana can lead to unauthorized deletion of data via Exploiting Incorrectly Configured Access Control Security Levels (CAPEC-180). An authenticated user holding Synthetics privileges scoped to a single Kibana space could permanently delete Synthetics monitors that are shared into spaces they have no access to. Where a monitor is associated ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82294	New	6.5	MEDI				Uncontrolled Resource Consumption (CWE-400) in Elasticsearch can lead to denial of service via Excessive Allocation (CAPEC-130).
CVE-2026-82300	New	6.5	MEDI				Uncontrolled Resource Consumption (CWE-400) in Elasticsearch can lead to denial of service via Excessive Allocation (CAPEC-130).
CVE-2026-84097	New	6.5	MEDI		0.002		The wp-review-slider-pro WordPress plugin before 12.7.12 does not sanitize a value stored through one of its AJAX handlers, which lacks a capability check, before using it in a SQL statement, allowing any authenticated user, such as a subscriber, to perform SQL injection attacks whose results are then returned to unauthenticated visitors.
CVE-2026-94396	New	6.5	MEDI				Uncontrolled Resource Consumption (CWE-400) in Elasticsearch can lead denial of service via Excessive Allocation (CAPEC-130)
CVE-2026-94397	New	6.5	MEDI				Uncontrolled Resource Consumption (CWE-400) in Elasticsearch can lead denial of service via Excessive Allocation (CAPEC-130)
CVE-2026-94398	New	6.5	MEDI				Uncontrolled Resource Consumption (CWE-400) in Elasticsearch can lead denial of service via Excessive Allocation (CAPEC-130)
CVE-2026-94399	New	6.5	MEDI				Uncontrolled Resource Consumption (CWE-400) in Elasticsearch can lead denial of service via Excessive Allocation (CAPEC-130)
CVE-2026-94400	New	6.5	MEDI				Uncontrolled Resource Consumption (CWE-400) in Kibana can lead denial of service via Excessive Allocation (CAPEC-130)
CVE-2026-100312	New	6.3	MEDI		0.002		A security flaw has been discovered in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbf3300d60c3494db3fb95b66e7be. The impacted element is an unknown function of the file /updateguest.php. Performing a manipulation of the argument gname/editassid results in sql injection. It is possible to initiate the attack remotely. The exploit has been released to the public ...
CVE-2026-100745	New	6.3	MEDI				A vulnerability has been found in Edimax BR-6428nC 1.16. The impacted element is an unknown function of the file /goform/formWizSurvey of the component Wireless Wizard Handler. The manipulation of the argument interface1/interface2 leads to stack-based buffer overflow. Remote exploitation of the attack is possible. The exploit has been disclosed to the public and may be used.
CVE-2026-100854	New	6.3	MEDI				AzuraCast before 0.23.6 lacks RequireInternalConnection middleware on the Liquidsoap API endpoint and incorrectly derives the AutoDJ flag from header presence rather than validated value. Users with View station permission can inject arbitrary now-playing metadata, disrupt live broadcasts, and disclose filesystem paths.
CVE-2026-72662	New	6.3	MEDI				Authorization Bypass Through User-Controlled Key (CWE-639) in Kibana can lead to unauthorized disclosure, modification, and deletion of data via Accessing Functionality Not Properly Constrained by ACLs (CAPEC-1). An authenticated user granted the Timeline feature privilege in a Kibana space could enumerate, read, modify, and delete draft Timeline objects belonging to other u...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100694	New	6.1	MEDI				Hugo is a static site generator. In versions from v0.56.0 through v0.165.x, content files mapped to the text/org media type are rendered without escaping raw HTML: Org export blocks and @@html:...@@ snippets pass HTML through unescaped, resulting in cross-site scripting (XSS) in the generated site. An attacker who can supply or influence a content file under /content or the ...
CVE-2026-100695	New	6.1	MEDI				Adminer before 6.0.2 contains a cross-site scripting vulnerability where the CONNECTION_ID() database result is interpolated into JavaScript without proper escaping, allowing a malicious database server to execute arbitrary JavaScript in the authenticated Adminer origin. In co-located deployments where the database has FILE privileges and can write to the webroot, attackers ...
CVE-2026-100701	New	6.0	MEDI				Nodemailer versions 5.0.0 through 10.0.1 use a process-global DNS cache that is keyed only by the DNS host, while each cache entry also stores the caller-specific TLS servername. When two direct TLS/SMTPS transports (secure: true) resolve the same non-IP host with different tls.servername values, the first transport's servername is returned on the cache hit and overwrites th...
CVE-2026-100635	New	5.9	MEDI				SiYuan before v3.8.4 contains an authentication bypass vulnerability in the publish service where session cookies are issued without Secure or SameSite attributes over plaintext HTTP connections. An on-path attacker can observe a valid publish-visitor-session-id cookie from a Basic Auth exchange and replay it to access authenticated publish endpoints without knowing the acco...
CVE-2026-100652	New	5.9	MEDI				vLLM versions 0.22.0 through 0.23.0 fail to validate stop_token_ids against vocabulary bounds in Rust HTTP and gRPC frontends, allowing out-of-vocabulary token IDs to reach MinTokensLogitsProcessor. Attackers can submit requests with min_tokens greater than zero and out-of-vocabulary stop_token_ids to trigger CUDA tensor indexing failures that leave EngineCore in a fatal sta...
CVE-2026-100689	New	5.9	MEDI				GitPython before 3.1.62 does not validate the `path` field read from an untrusted .gitmodules file when updating submodules. While a prior fix (GHSA-hmq2-w58f-27jc) added Submodule._validated_name() to constrain the `name` field, and GitPython's own containment guard Submodule._to_relative_path() is applied in add() and move(), Submodule.update() derives the absolute checkou...
CVE-2026-100834	New	5.9	MEDI				http4k's Digest authentication module (org.http4k:http4k-security-digest) before versions 6.48.0.0, 5.42.0.0 and 4.51.0.0 defaults the nonceVerifier parameter of ServerFilters.DigestAuth and DigestAuthProvider to { true }, so every nonce is accepted regardless of its value, age, or prior use. Applications relying on this default have no replay protection on Digest authentica...
CVE-2026-100853	New	5.9	MEDI				In AzuraCast before 0.23.8, the public On-Demand download endpoint fails to verify playlist-level access controls, allowing unauthenticated users to download media files excluded from On-Demand-enabled playlists. Attackers can bypass the station operator's intended access restrictions by directly requesting media via the download endpoint using valid media identifiers, expos...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-19708	New	5.9	MEDI		0.001		The File Manager WordPress plugin before 8.0.5 does not prevent unauthenticated users from downloading its database backup archives, and in some cases writes them under a fixed filename, allowing unauthenticated attackers to retrieve a full database dump including every user's email address and password hash on servers that do not apply the directory's .htaccess file.
CVE-2026-100696	New	5.8	MEDI				Adminer 4.16.0 through 6.0.1 contain a pre-authentication Server-Side Request Forgery (SSRF) vulnerability in the optional Elasticsearch driver (plugins/drivers/elastic.php), fixed in 6.0.2. Because adminer/include/auth.inc.php invokes Driver::connect() before the login result is validated, an unauthenticated attacker who submits crafted auth[server], auth[username], and aut...
CVE-2026-100698	New	5.8	MEDI				Adminer 5.5.1 through 6.0.1 improperly parses the login 'server' string in the host_port() function in adminer/include/functions.inc.php. The port capture group requires pure digits anchored to the end of the string, so any server value with a non-digit tail fails the regex and falls back to returning the whole string as the host with an empty port. Because the privileged-po...
CVE-2026-96533	New	5.8	MEDI		0.001		The Testimonials Widget WordPress plugin through 4.0.4 does not validate a user-supplied URL before fetching it server-side and storing the response as a public file, allowing unauthenticated users to make the server issue requests to internal services and read the responses.
CVE-2025-71422	New	5.7	MEDI				Contrast is a Kubernetes runtime for confidential containers. In versions before 1.12.1, the secure persistent volume feature is vulnerable to a malicious host supplying a crafted LUKS2 volume to a pod VM. LUKS2 volume metadata is not authenticated and, with cryptsetup versions prior to 2.8.1, a header specifying the null keyslot encryption algorithm (cipher_null-ecb) is acc...
CVE-2026-100616	New	5.5	MEDI				capgo.app is an over-the-air update platform for Capacitor apps. In all versions prior to a fix, the row-level security UPDATE policy on the public.orgs table permits an organization admin (a user holding org.update_settings) to update the entire row, including the internal billing pointer column customer_id. The official organization update endpoint (supabase/functions/_bac...
CVE-2026-100629	New	5.5	MEDI				Capgo (capgo.app backend) before 12.127.5 contains an authorization flaw in the PATCH /private/role_bindings/:binding_id endpoint. The handler verifies that the newly assigned role's priority rank does not exceed the caller's own rank, but — unlike the DELETE handler — it never checks the rank of the role currently bound to the target binding. An authenticated user holding t...
CVE-2026-100687	New	5.5	MEDI				Budibase Server before 3.45.0 fails to redact plaintext datasource credentials before broadcasting external table updates to the Builder collaboration websocket room. Attackers with Builder access can intercept unredacted datasource objects containing database passwords and API keys by observing table save or delete operations.
CVE-2026-100860	New	5.5	MEDI				heym before 0.0.105 does not act on the result of the credential authorization lookup in the Redis workflow node (backend/app/services/node_execution/nodes/redis_node.py). When _get_accessible_credential returns None — because the credential ID does not exist or the caller is not authorized to use it — the node treats the lookup failure as an empty configuration and falls ba...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100603	New	5.4	MEDI				ClawHub (openclaw/clawhub) application/backend contains a flaw in the skill report moderation flow: four distinct ordinary authenticated accounts can report a visible skill and trigger automatic hiding (moderationStatus: hidden) of that skill from the catalog without any moderator decision. Because the reporter quota counts only reports filed against visible targets, the sam...
CVE-2026-100604	New	5.4	MEDI				ClawHub (openclaw/clawhub) contains an incorrect authorization vulnerability in the ClawHub application/backend: an organization-owned skill retains the ownerUserId of its original publisher, and transfer and lifecycle authorization checks trust that historical user before requiring current organization privileges. An authenticated user who originally published an organizati...
CVE-2026-100624	New	5.4	MEDI				Capgo.app before 12.264.5 does not enforce upload expiry or build lifecycle state in the /build/upload/jobId TUS proxy endpoint. When a native build request is created, an upload_expires_at timestamp (one hour) and a 'pending' status are stored in build_requests, but the upload proxy loads only app_id, owner_org, builder_job_id, and upload_path and checks only the app.build...
CVE-2026-100630	New	5.4	MEDI				AVideo contains a stored cross-site scripting vulnerability in the video trailer1 field rendered unsanitized within an inline onclick JavaScript string. Attackers with video upload permission can store HTML entity-encoded payloads that bypass isValidURL() validation and are decoded by the browser to break out of the JavaScript string, executing arbitrary code in any visitor'...
CVE-2026-100681	New	5.4	MEDI				Budibase before 3.45.0 contains an unauthenticated server-side request forgery and credential exfiltration vulnerability in the Microsoft Teams webhook endpoint that accepts forged Bot Framework activities with arbitrary serviceUrl values. Attackers can submit a crafted POST request to inject an attacker-controlled serviceUrl that is persisted and used for all subsequent bot...
CVE-2026-100691	New	5.4	MEDI				Hugo versions 0.75.0 through 0.165.x contain a stored cross-site scripting vulnerability: the syntax highlighter does not escape the `lineAnchors` option before passing it to Chroma, which writes the value verbatim into the `id` and `href` attributes of the generated line-number markup. A crafted `lineAnchors` value supplied as a Markdown code fence attribute (or passed to t...
CVE-2026-100724	New	5.4	MEDI				http4k (Maven package org.http4k:http4k-core) before 6.49.0.0, 5.42.0.0 and 4.51.0.0 uses substring (Contains) matching on the Host header by default in reverseProxy() and reverseProxyRouting() when dispatching to configured virtual hosts. If these functions are deployed as a public-facing inbound HTTP handler with two or more configured virtual hosts, a remote attacker can ...
CVE-2026-100600	New	5.3	MEDI				ClawHub (the openclaw/clawhub application/backend) does not bind anonymous HTTP API requests to a trusted caller identity, so all direct anonymous API requests share a single default quota allowance. A remote, unauthenticated caller can drain that shared allowance and thereby deny or degrade API access for unrelated visitors. In addition, when the TRUST_FORWARDED_IPS option ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100601	New	5.3	MEDI				ClawHub (openclaw/clawhub) application/backend contains a server-side request forgery vulnerability in the public profile preview's image fetching. The preview accepts a user-supplied image URL and checks the textual hostname against private-address patterns, but does not validate or pin the resolved network destination, so a public-looking hostname can resolve to an interna...
CVE-2026-100613	New	5.3	MEDI				capgo.app is an over-the-air (OTA) update platform for Capacitor apps. In all versions up to and including the current release (no patch available at time of publication), the `transfer_app()` database function transfers an app, its channels, versions and related records to a destination organization without deleting or revalidating existing rows in `channel_permission_overn...
CVE-2026-100626	New	5.3	MEDI				capgo through 12.128.2 contains an insecure direct object reference vulnerability in the PUT /app/:appid endpoint that accepts attacker-controlled icon storage paths. Authenticated users can supply arbitrary paths in the private images bucket and obtain service-role-signed URLs valid for 7 days to read cross-tenant objects including user avatars, organization logos, and app ...
CVE-2026-100647	New	5.3	MEDI				vLLM versions before 0.29.0 contain a denial-of-service vulnerability in the cache_salt parameter accepted on OpenAI-compatible and Anthropic API endpoints, which lacks maximum length validation and is processed on the single EngineCore scheduler thread. Unauthenticated attackers can send HTTP requests with multi-hundred-megabyte salt values that trigger expensive pickle ser...
CVE-2026-100648	New	5.3	MEDI				vllm before 0.29.0 fails to enforce VLLM_MAX_AUDIO_CLIP_FILESIZE_MB limit in multimodal chat audio decoding, allowing unauthenticated clients to bypass file size restrictions. Attackers can submit oversized audio files through chat endpoints to consume excessive memory and CPU resources during decoding.
CVE-2026-100658	New	5.3	MEDI				Netty (io.netty:netty-codec-http) contains an unbounded per-connection queue in WebSocketServerExtensionHandler. The handler offers an entry to its per-channel validExtensions queue for every inbound HttpRequest, but polls an entry only when the application writes an HttpResponse, and the queue size is never bounded. A remote, unauthenticated peer can use HTTP/1.1 pipelining...
CVE-2026-100667	New	5.3	MEDI				grav-plugin-login (the Grav CMS Login plugin) versions >= 3.8.7 and < 3.9.7 allow the two-factor authentication challenge to be bypassed for content gated by the authenticated() Twig function or the [authenticated] shortcode. On sites with 2FA enabled, Login::isAuthenticated() checked only the session flag indicating that the password step had succeeded, not the flag indicat...
CVE-2026-100677	New	5.3	MEDI				stoatchat before 0.15.5 contains an account enumeration vulnerability in the login endpoint that exposes source file locations in error responses. Unauthenticated attackers can distinguish between registered and unregistered email addresses by comparing error location fields returned from POST /api/auth/session/login requests.
CVE-2026-100699	New	5.3	MEDI				Nodemailer is a Node.js email-sending library. In versions >= 9.1.0 and < 10.0.9, the address parser (src/addressparser) mishandles addresses whose local-part is a quoted string and that are followed by RFC 5322 comments, allowing trailing comment-separated domain atoms to be retained in the normalized address. For example, the input "user"@example.com(x)evil.com is parsed t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-11871	New	5.3	MEDI		0.001		The Team Members WordPress plugin through 9.2 does not perform any authorization or visibility check in an unauthenticated AJAX action that returns full team member records by ID, allowing unauthenticated attackers to enumerate and disclose details, including email addresses and phone numbers, of team members the administrator has not published publicly.
CVE-2026-100861	New	5.0	MEDI				heym before 0.0.105 fails to apply egress guards to integration services that use credential-supplied base URLs, allowing authenticated users to bypass SSRF protections. Attackers can configure credentials pointing to loopback, private, or cloud-metadata addresses and read internal service responses returned as workflow node output.
CVE-2026-100863	New	5.0	MEDI				Heym versions 0.0.90 and earlier contain two server-side request forgery (SSRF) egress gaps, both remediated in app/services/ssrf_guard.py in 0.0.91. First, the LLM image-edit input loader (_load_image_bytes) fetched caller-controlled HTTP/HTTPS URLs with a bare httpx.get, applying only a scheme check and bypassing the egress-pinning HTTP client; because the workflow DSL sup...
CVE-2026-100862	New	4.9	MEDI				heym, a workflow automation platform, stores and returns multiple capability secrets in plaintext in versions prior to 0.0.91. Affected secrets include webhook header-auth values (returned in cleartext by GET /api/workflows/{id} and persisted unsanitized into execution history), MCP API keys (stored as a plaintext column, returned in config/list responses, and accepted via t...
CVE-2026-94408	New	4.9	MEDI				Uncontrolled Resource Consumption (CWE-400) in Elasticsearch can lead denial of service via Excessive Allocation (CAPEC-130)
CVE-2026-100634	New	4.7	MEDI				SiYuan before v3.8.4 does not validate the sender or restrict recipients in the 'siyuan-send-windows' IPC handler of the Electron main process (app/electron/main.js). The handler ignores event.sender and forwards any received payload to every BrowserWindow returned by BrowserWindow.getAllWindows(), including windows belonging to other opened workspaces. A renderer connected ...
CVE-2026-100640	New	4.7	MEDI				SiYuan before v3.8.4 contains an authorization omission in the siyuan-get IPC handler that allows remote-kernel renderers to access native clipboard formats by invoking clipboardReadMathML, clipboardReadOffice, and clipboardReadWPS commands with matching plaintext. Attackers controlling remote renderer content can obtain MathML formulas, Office bytes, and WPS bytes from loca...
CVE-2026-100313	New	4.3	MEDI				A weakness has been identified in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbf3300d60c3494db3fb95b66e7be. This affects an unknown function of the file updatequery.php. Executing a manipulation of the argument queryx can lead to cross site scripting. It is possible to launch the attack remotely. The exploit has been made available to the public and could be us...
CVE-2026-100621	New	4.3	MEDI				Capgo (capgo.app) contains an incomplete access-control/content-lock enforcement issue affecting all versions; no patch is available at the time of publication. The `enforce_encrypted_bundle_trigger` / `check_encrypted_bundle_on_insert` content lock in supabase/schemas/prod.sql exempts `app_versions` rows whose previous `storage_provider` is `r2-direct`, so delivery-critical...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100628	New	4.3	MEDI				capgo.app before 12.128.12 fails to enforce an organization's API key expiration policy when creating app-scoped API keys. In the POST /apikey endpoint, requests that supply app_id but omit org_id, limited_to_orgs, and expires_at resolve the target app and scope the key to it, but never add the app's owner organization to the list of organization IDs passed to validateExpira...
CVE-2026-100674	New	4.3	MEDI				stoatchat before 0.15.5 fails to revalidate usernames after Unicode sanitization, allowing attackers to create usernames with forbidden characters by submitting Unicode letters that transform into rejected characters. Attackers can bypass character allowlists and length limits to create reserved-name lookalikes, embed special characters, and exceed the 32-character storage l...
CVE-2026-100836	New	4.3	MEDI				Contrast through 1.20.0 contains a panic vulnerability in the transit-engine endpoint's ciphertextContainer.UnmarshalJSON function that fails to validate decoded ciphertext length before slicing. An authenticated workload with a valid mesh certificate can trigger a runtime panic by submitting a short base64-encoded ciphertext, causing log spam and request failures without cr...
CVE-2026-100620	New	3.8	LOW				Capgo CLI (npm package @capgo/cli) through 7.98.2 is affected by an over-permissioned service account in its Android onboarding flow. When onboarding via Google OAuth, the CLI invites the generated Google Play service account with the account-wide Play Console permission CAN_MANAGE_DRAFT_APPS_GLOBAL (passed as developerAccountPermissions in the Android Publisher API User cre...
CVE-2026-100649	New	3.7	LOW				vLLM before 0.29.0 contains a resource-limit bypass vulnerability in PyNvVideoCodec decoder allocation where sampler subclass shadowing allows independent counter increments. Unauthenticated attackers can select different sampler subclasses in video requests to exceed configured decoder limits and exhaust unaccounted GPU memory.
CVE-2026-100837	New	3.7	LOW				Contrast (Edgeless Systems) through 1.20.0 performs unanchored suffix matching when selecting per-registry configuration in the imagepuller. Config.registryFor strips a single trailing dot and then uses strings.HasSuffix(hostname, fqdn) without requiring a DNS label boundary, so a registry entry such as [registries."ghcr.io."] is also applied to any host whose name merely en...
CVE-2025-71424	New	3.5	LOW				Contrast, Edgeless Systems' runtime for confidential containers on Kubernetes, is affected in versions up to and including 1.9.0. The VOLUME directive in a Dockerfile (config.volumes in the OCI image configuration) is only a hint and is not handled specially by Kubernetes, but containerd adds a mount point for it when Kubernetes sets none, requiring the runtime to be able to...
CVE-2026-100311	New	3.5	LOW		0.002		A vulnerability was identified in mathurvishal CloudClassroom-PHP-Project up to 5dadec098bfbbf3300d60c3494db3fb95b66e7be. The affected element is an unknown function of the file managevideos2.php of the component Faculty Video Management. Such manipulation of the argument V_Title/V_Url/V_Remarks leads to cross site scripting. The attack may be performed from remote. The expl...
CVE-2026-96525	New	2.7	LOW		0.001		The MCP Server for WordPress WordPress plugin before 1.8.2 does not perform an ownership or sufficient capability check on its workflow create, update and delete REST routes, allowing users with the Contributor role to modify, delete and create site-wide workflow configuration, including workflows created by administrators.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96526	New	2.7	LOW		0.001		The MCP Server for WordPress WordPress plugin before 1.8.2 does not perform an object-level authorization check on one of its workflow REST routes, allowing users with the Contributor role to disclose the title and publication status of any post, page or custom post type, including other users' private, draft, pending and scheduled content.
CVE-2026-98163	New				0.002		In the Linux kernel, the following vulnerability has been resolved: cgroup: Avoid iteration of dying tasks with zero refcount The commit 260fbc92bba ("cgroup: Move dying_tasks cleanup from cgroup_task_release() to cgroup_task_free()") extended the lifetime of tasks on the dying_tasks list. The iterators have provision to go through dying_tasks because of dying threadgrou...
MAL-2026-17189	New					npm:chai-as-relay	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (5c65319b0e17f945fc57f482eb174e5d7fe70e63a380cb24f64eea1808bdad2f) Package main index.js unconditionally requires ./lib/config at module load. lib/config.js is a single-line ~4.4MB obfuscator.io-packed IIFE (hex-escaped string-array of 26,102 entries, rotated with wrapper decoders, contr...
MAL-2026-17190	New					npm:cma-self-hosted-sandbox-cf	--- _-= Per source details. Do not edit below this line.=-_ ## Source: amazon-inspector (d91a7568b717361d5b3727d46e8bf567fc038f95c5fa22c5222a272460bb9f35) package.json declares a preinstall hook that runs index.js on npm install. index.js collects the machine's hostname, current user info, home directory, configured DNS servers, and the contents of /etc/passwd and /etc/hos...
MAL-2026-17191	New					PyPI:requests-cache-utils	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (1655ea47fc7ccd39294203776ee3dcb01a394c40d93e05b7b527700b19de42c8) During installation and importing the module, the code downloads and executes an infostealer. --- Category: MALICIOUS - The campaign has clearly malicious intent, like infostealers. Campaign: 2026-09-requests-cache-utils Re...
MAL-2026-17192	New					PyPI:donutautosellsrc	--- _-= Per source details. Do not edit below this line.=-_ ## Source: kam193 (2ac1203ac68b4bb062c4dd38f59fd8bd13fef695c5b1c8059160c6a5205717b1) During installation package fetches code hidden in an image containing a Python application with a native extension module. This module holds an obfuscated infostealer which collects sensitive data and exfiltrates them to a C2 ser...

Significant updates today - original Published Date retained

None in this window.

Added to CISA KEV today

None in this window.

P1 new today

None in this window.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97163	New	10.0	CRIT				Joomla Extension - lomart.fr - Unauthenticated remote code installation in UP plugin extension 5.0.0-5.2.0, 6.0.0-6.0.29
CVE-2026-100716	New	9.9	CRIT				Froxlор is a server administration panel. In versions 2.3.10 and earlier, the customer data-export (DataDump) cron fails to validate intermediate path components of the export destination: Froxlор\FileDir::makeCorrectDir() contains an off-by-one in its path-component walk that skips the first segment below the customer home directory, and the guard in ExportCron.php checks o...
CVE-2026-100717	New	9.9	CRIT				froxlор is a server administration panel. In versions 2.3.10 and earlier, Validate::validateUrl rejects carriage return and line feed characters only in the path, query and fragment components returned by parse_url, and never inspects the userinfo (user:pass@) components. This is an incomplete fix for GHSA-c3p2. An authenticated low-privilege customer with subdomain-create r...
CVE-2026-100740	New	9.9	CRIT				A vulnerability was detected in D-Link DIR-895L A1_102b07. Impacted is the function tunnel_set_params of the file tunnel.c of the component L2TP Control Channel Parser. Performing a manipulation results in out-of-bounds write. The attack may be initiated remotely. The exploit is now public and may be used.
CVE-2026-18143	New	9.8	CRIT		0.004		The Request a Quote for WooCommerce plugin for WordPress is vulnerable to Arbitrary File Upload in all versions up to, and including, 2.9.2 via the `afrfq_submit_quote_via_popup()` function. This is due to missing file extension and MIME type validation in the popup upload handler, which uses the raw attacker-supplied filename directly as the destination for `move_uploaded_f...
CVE-2026-82901	New	9.8	CRIT				The Ultra Addons for Contact Form 7 plugin for WordPress is vulnerable to Arbitrary File Upload due to insufficient file type validation in the 'uacf7_wpcf7_mail_components' function in all versions up to, and including, 3.5.50. This makes it possible for unauthenticated attackers to upload arbitrary files on the affected site's server which may make remote code execution po...
CVE-2026-85984	New	9.8	CRIT				The miniOrange OTP Login, Verification and SMS Notifications plugin for WordPress is vulnerable to Authentication Bypass via the mo_wp_login_intent parameter in all versions up to, and including, 5.5.5. This is due to a missing password-intent guard in the skip_pass_fallback-enabled configuration branch of the mo_by_pass_login() function, which treats administrator role memb...
CVE-2026-100715	New	9.6	CRIT				Froxlор through 2.3.10 is vulnerable to arbitrary file deletion via symlink following in the FTP data deletion cron task. Cron task 8 (deleteFtpData), queued when an FTP account is deleted, calls FileDir::makeCorrectDir() without the \$fixed_homedir argument, so the symlink component walk is skipped, and then executes `rm -rf` as root on the resulting path with string-level g...
CVE-2026-94132	New	9.5	CRIT				Joomla Extension - acymailing.com - Remote Code Execution vulnerability in mailbox action feature in AcyMailing Enterprise extension < 11.1.0 - MIME parts of incoming emails were saved to media/com_acym/upload/ with no extension check, so anyone who could email the monitored mailbox could write a PHP file into the web root.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100706	New	9.4	CRIT				kyverno before 1.19.1 fails to properly validate URL-encoded path segments in Policy apiCall urlPath, allowing namespace tenants to bypass the per-namespace clamp and create objects in other namespaces as the admission-controller ServiceAccount. Attackers can exploit this by using percent-encoded directory traversal sequences to create MutatingWebhookConfiguration objects cl...
CVE-2026-100714	New	9.4	CRIT				Froxlор before 2.3.12 does not restrict or escape the system.letsencryptchallengepath setting: unlike sibling settings hardened in GHSA-33mp, the field has no string_regexp or required_otp guard, and its value is concatenated unescaped into the acme.sh command line built in lib/Froxlор/Cron/Http/LetsEncrypt/AcmeSh.php and executed by the root cron via FileDir::safe_exec. Bec...
CVE-2026-97160	New	9.4	CRIT				Joomla Extension - lomart.fr - Authenticated, privileged PHP command injection in UP plugin extension 5.0.0-5.2.0, 6.0.0-6.0.29
CVE-2026-100720	New	9.3	CRIT				Froxlор 2.0.0 through 2.3.10 is vulnerable to stored cross-site scripting. When a customer (the lowest-privileged authenticated role) uploads an SSL certificate for one of their own domains, the Certificates API add()/update() methods parse it with openssl_x509_parse() and store the issuer organization (issuer['O']) value verbatim without sanitization. Froxlор's table-listin...
CVE-2026-94130	New	9.3	CRIT				Joomla Extension - joomlaboat.com - Unauthenticated SQL injection in YouTube Gallery extension < 5.7.3 - An SQL injection vulnerability in video search functionality and sorting allowed attackers to inject SQL commands in read queries.
CVE-2026-97161	New	9.2	CRIT				Joomla Extension - lomart.fr - Various path traversal / file access vectors in UP plugin extension 5.0.0-5.2.0, 6.0.0-6.0.29
CVE-2026-100721	New	9.0	CRIT				vm2 before 3.12.2 contains an authorization bypass in the NodeVM external-module resolver. When an embedder configures `require.external` with a custom resolver (and `context: 'host'`), `LegacyResolver.customResolve` in lib/resolver-compat.js records the resolved module directory in `this.externals` as `new RegExp('^' + escapeRegExp(resolvedPath))`, without requiring a path ...

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.